DisputeDesk — Phase 2.2 Report

Final verification of the session cookie, CSRF checks, session expiry and the production CSP

Date **3 November 2026** Audited commit **bd1f620** (Phase 2.1)

Type **Audit and report wording fix — no code changed** Branch **master**

Summary. The session cookie is configured correctly. The server never sends a `Domain` attribute, and the browser stores the cookie as host-only. All `__Host-` prefix rules hold on both the dev server (`localhost:5173`) and the production build (`localhost:4173`). The only error found is wording in the Phase 2.1 report, which says "Domain=localhost". `localhost` is only the host the browser files the cookie under, not an attribute the server sends. That wording was corrected after approval, and all tests and checks were run again and pass. Cookie values in this report are redacted.

0	22/22	22/22	0
Domain attributes sent	Browser checks, production build	Browser checks, dev server	Code changes, PayPal or Gemini calls

1. Raw Set-Cookie headers

Captured from the browser's network log. Identical on `localhost:5173` and `localhost:4173` .

```
Sign-in  200:  __Host-dd_session=<redacted, 43 chars>; Path=/; Max-Age=28800; HttpOnly; Secure; SameSite=St
rict
Sign-out 204:  __Host-dd_session=; Path=/; Max-Age=0; HttpOnly; Secure; SameSite=Strict
```

Attribute	Sign-in	Sign-out	Result
Name	`__Host-dd_session`	`__Host-dd_session`	Match
Domain	not sent	not sent	Host-only
Path	`/`	`/`	Match
Secure	yes	yes	Match
HttpOnly	yes	yes	Match
SameSite	`Strict`	`Strict`	Match
Max-Age	`28800` (8 hours)	`0` (delete)	Expected difference
Blocked by browser	no	no	Accepted

2. Cookie as the browser stores it

From Chrome's DevTools protocol (`Network.getAllCookies`) after sign-in.

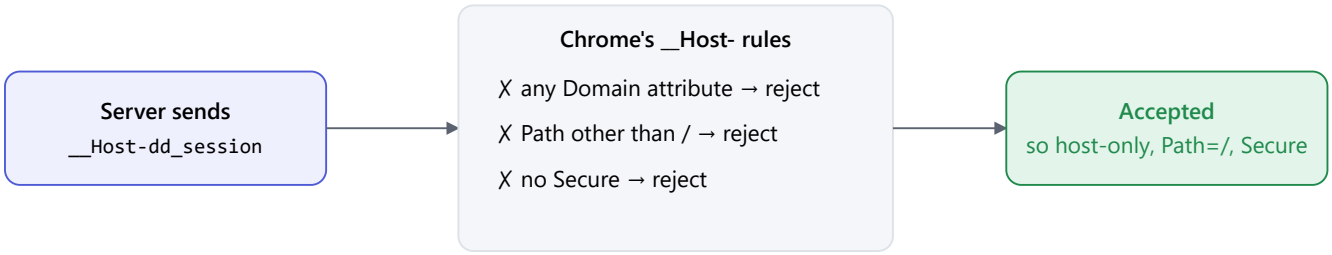
Field	Value	Field	Value
name	`__Host-dd_session`	sameSite	`Strict`
domain	`localhost` (storage host)	session	`false` (expires in about 8 h)
path	`/`	sourceScheme	`Secure`
httpOnly	`true`	sourcePort	`5173` or `4173`
secure	`true`	size	`60`

- **`document.cookie`:** `""` on both servers. Page scripts cannot read the session.
- **Next API request** (`/api/disputes`): the cookie was sent.
- **After sign-out:** the browser no longer holds the cookie.

3. Host-only versus Domain

The DevTools protocol has no `hostOnly` field, so the stored `domain` value alone cannot prove the cookie is host-only. Control cookies were set in the same browser on `localhost:4173` :

Control cookie	Result
`probe_hostonly; Path=/`	Stored, `domain="localhost"`
`probe_domain; Path=/; Domain=localhost`	Stored, `domain="localhost"` — **same as above**
`__Host-probe_ok; Path=/; Secure`	Stored
`__Host-probe_domain; Path=/; Secure; Domain=localhost`	Rejected
`__Host-probe_path; Path=/api; Secure`	Rejected
`__Host-probe_insecure; Path=/` (no Secure)	Rejected



The proof. Chrome refuses any `__Host-` cookie with a Domain, a non-root Path, or no Secure flag. It accepted `__Host-dd_session` , so the cookie meets all three rules and is host-only.

- **Storage domain is not an attribute.** On `localhost` , Chrome files a cookie with and without `Domain=localhost` identically, so the stored value proves nothing either way.
- **`Secure` on plain HTTP.** `sourceScheme: "Secure"` confirms Chrome treats `http://localhost` as a secure origin.
- **Ports.** Cookies are not tied to a port, so a session from 5173 also works on 4173. Both pages use the same API, so this is expected.
- **Tests already lock this in.** The sign-in test matches the whole header exactly: `/^__Host-dd_session=[A-Za-z0-9_-]{43}; Path=\/; Max-Age=28800; HttpOnly; Secure; SameSite=Strict$/` . The sign-out tests (`app.test.ts` and `auth.test.ts`) compare the cleared header exactly. Adding a Domain attribute would fail them.

4. Other checks

Area	Evidence	Result
Origin and Sec-Fetch-Site	A sign-out form posted from another site got **403**; the session survived. Server tests refuse cross-site and same-site `Sec-Fetch-Site` even without an Origin header.	Pass
Sign-out	Replaying a signed-out cookie gets **401** on every protected route.	Pass
Expiry	Tests pass for 30 minutes idle, 8 hours after sign-in, and a new token on each sign-in.	Pass
Production CSP	`default-src 'self'; script-src 'self'; style-src 'self'; img-src 'self' data:; connect-src 'self'; font-src 'self'; object-src 'none'; base-uri 'none'; form-action 'self'; frame-ancestors 'none'` No `unsafe-*`; no violations in the browser.	Pass
Dev CSP	Looser by design, because Vite's live reload needs inline code. It keeps `object-src`, `base-uri`, `form-action` and `frame-ancestors`.	As intended
Browser checks	22 checks on each server, including sign-in, roles, cookie flags, cross-site refusal and CSP.	22/22 and 22/22

The page headers come from Vite's preview server. Any real hosting must send the same headers.

5. Correction applied (wording only)

- **No code change.** The cookie was already correct, and the exact-match tests already guard it. An extra "no Domain" test would repeat them.
- **Phase 2.1 report:** "Domain=localhost (host-only)" now reads "No Domain attribute is sent (host-only). Browser storage lists the host as localhost." in item 5 and browser check #4. `reports/phase-2.1-report.pdf` was re-rendered.
- **Check script:** the cookie line now prints `Path=/; no Domain attribute (host-only); browser storage host localhost`.

Verification after the fix	Result
Server tests	113/113
Client tests	53/53
Server and client type checks	Pass
Production build	Pass
Browser checks, production build (`localhost:4173`)	22/22
Browser checks, dev server (`localhost:5173`)	22/22

6. Method and limits

- **Tools:** headless Chrome driven over the DevTools protocol, already on this machine. Nothing was installed.
- **Skills:** security-and-hardening, test-driven-development, api-and-interface-design, Ponytail and ECC security-review.
- **Not changed:** code, tests, security headers and `.env`. No PayPal or Gemini calls. Nothing committed or pushed.
- **Not covered:** browsers other than Chrome, and real HTTPS hosting.